

Historia de Usuario con buenas prácticas IEEE 29148

ID: HU-002

Título: Autenticación de usuarios en el sistema

1. Descripción (Claridad y ausencia de ambigüedad)

Como **usuario registrado**, quiero **iniciar sesión en el sistema mediante correo y contraseña**, para **acceder de forma segura a mis datos personales**.

- **Evita ambigüedades:** No se dice “acceso rápido” o “inicio de sesión seguro”, se detalla cómo y qué se valida.
 - **Métrica concreta:** El proceso de autenticación debe completarse en **menos de 2 segundos** en condiciones de red estándar (10 Mbps).
-

2. Atributos (Compleitud)

- **Fuente:** Área de Seguridad y usuarios finales.
 - **Prioridad:** Esencial.
 - **Estado:** Aprobado.
 - **Versión:** 1.1.
 - **Restricciones:**
 - La contraseña debe tener mínimo 8 caracteres, incluir mayúsculas, minúsculas, un número y un carácter especial.
 - Tres intentos fallidos bloquean la cuenta durante 15 minutos.
 - **Dependencias:** Requiere la base de datos de usuarios habilitada.
-

3. Criterios de Aceptación (Consistencia)

1. El sistema debe validar que el correo existe en la base de datos.
2. El sistema debe encriptar la contraseña utilizando **SHA-256** antes de la validación.
3. El tiempo de respuesta debe ser $\leq$ **2 segundos**.
4. El usuario con credenciales válidas debe ser redirigido a su panel personal.
5. No puede existir contradicción: el sistema exige seguridad (bloqueo tras intentos fallidos) y al mismo tiempo disponibilidad (usuario puede reintentar luego de 15 min).

4. Trazabilidad

- **Origen:** Requisito de seguridad definido en la política interna de TI y solicitado por el usuario final.
- **Prueba asociada:** Caso de prueba CP-Login-001 valida inicio de sesión correcto; CP-Login-002 valida bloqueo tras intentos fallidos.
- **Normativa relacionada:** Cumple con OWASP Authentication Guidelines.

5. Verificabilidad

- **Medible en pruebas funcionales y de rendimiento:**
 - Se puede ejecutar una prueba automática para comprobar que el login toma $\leq$ 2 segundos.
 - Se puede probar que el bloqueo ocurre tras 3 intentos fallidos.
 - Se puede comprobar que la contraseña no se almacena en texto plano.

6. Priorización

- **Esencial:** Autenticación básica con correo y contraseña.
 - **Importante:** Bloqueo de cuenta tras intentos fallidos.
 - **Deseable:** Integración futura con autenticación biométrica (huella digital/rostro).
-

 Este ejemplo cumple con:

1. **Claridad** → No hay ambigüedad y se usan métricas.
2. **Compleitud** → Incluye restricciones, dependencias y fuente.
3. **Consistencia** → No hay contradicciones entre seguridad y disponibilidad.
4. **Trazabilidad** → Relacionado con su origen, normativa y pruebas.
5. **Verificabilidad** → Se valida con pruebas concretas.
6. **Priorización** → Clasificado en esencial, importante y deseable.